IP Addresses, Subnets & CIDR

design the address space before you need it

Watch the 5-min video

In one line: an IPv4 address is 32 bits; CIDR (`/16`, `/24`) says how many of those bits are the fixed network part; you carve a VPC's block into subnets per zone and keep databases in private subnets with no route from the internet.

1 What an IP address is

Every machine on a network needs an address. In the cloud you design that address space yourself, and a bad plan is painful to change later, so it is worth getting right on day one.

An **IPv4** address is **32 bits**, written as four numbers from 0 to 255 (each one 8 bits, an *octet*), for example `10.0.1.25`. That gives 2^{32} ≈ **4.3 billion** addresses, and the internet ran out of fresh ones years ago. **IPv6** uses **128 bits**, written in hexadecimal (like `2001:db8::1`), so addresses are effectively unlimited.

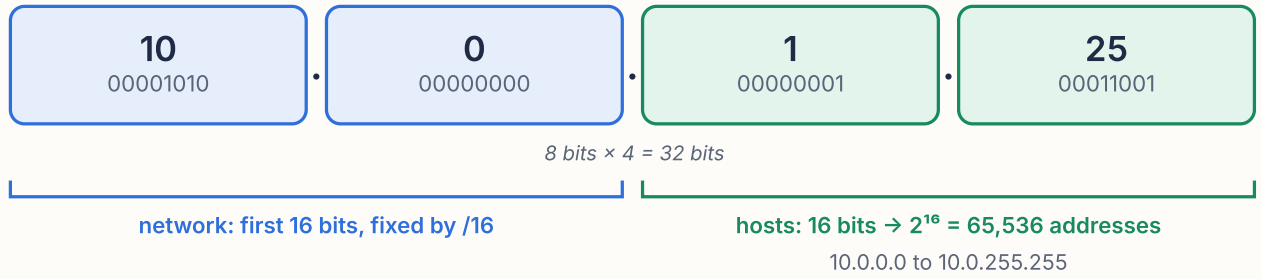


Figure 1. `10.0.1.25` is four 8-bit numbers. With `/16`, the first 16 bits are the network; the last 16 bits number the hosts.

2 Private ranges and NAT

Three ranges are reserved for internal networks (RFC 1918). They are not routed on the public internet, so every company can reuse them:

Range	CIDR	Size
`10.0.0.0 – 10.255.255.255`	`10.0.0.0/8`	16.7 million addresses: the usual choice for cloud VPCs
`172.16.0.0 – 172.31.255.255`	`172.16.0.0/12`	1 million. Only 172.**16** to 172.**31**; 172.15 and 172.32 are public
`192.168.0.0 – 192.168.255.255`	`192.168.0.0/16`	65,536: typical for home and office networks

To reach the internet, private machines go through **NAT** (network address translation). NAT swaps the private source address for a shared public one, remembers the mapping, and sends replies back to the right machine.

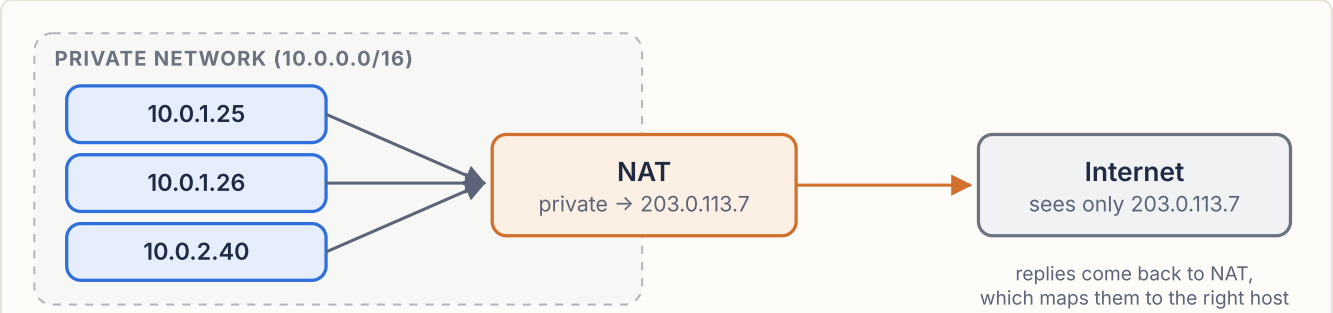


Figure 2. Many private hosts share one public address through NAT. The internet never sees the 10.x addresses.

3 CIDR: reading a block

CIDR notation (said "cider") describes a block of addresses as *start address / prefix length*. In `10.0.0.0/16`, the **/16** means the first 16 bits are the network part and are fixed. The other 32 − 16 = 16 bits are for hosts, so the block holds 2^{16} = **65,536** addresses, from `10.0.0.0` to `10.0.255.255`.

$$\text{addresses in a /n block} = 2^{(32 - n)}$$

A **bigger number after the slash means a smaller block**. Each extra bit halves it:

Prefix	Host bits	Addresses	Example	Usable on AWS (minus 5)
`/16`	16	65,536	`10.0.0.0 – 10.0.255.255`	a whole VPC
`/20`	12	4,096	`10.0.16.0 – 10.0.31.255`	4,091
`/24`	8	256	`10.0.1.0 – 10.0.1.255`	251
`/28`	4	16	`10.0.1.0 – 10.0.1.15`	11 (smallest AWS subnet)

4 Subnets: splitting the block

You split a big block into smaller **subnets**. Carve the `/16` into `/24`s and you get 2^8 = **256** of them: `10.0.0.0/24`, `10.0.1.0/24`, `10.0.2.0/24`, and so on up to `10.0.255.0/24`. Subnets don't have to be equal: you could use a few `/20`s for big app tiers and `/24`s for the rest, as long as they don't overlap.

In the cloud, **each subnet lives in exactly one availability zone**, and the provider reserves a few addresses in each. On AWS that is **five**: the network address, the next three (VPC router, DNS, reserved for future use) and the last (broadcast). So a `/24` gives 251 usable addresses.

5 Designing a real VPC

The example: a VPC with `10.0.0.0/16` across two availability zones, with three tiers of subnets in each zone.

- **Public subnets** hold only the load balancers (and the NAT gateways). Their route table sends `0.0.0.0/0` to the **internet gateway**.
- **Private app subnets** hold your services. Their default route goes to a **NAT gateway**: outbound only, for things like calling a payment API or pulling updates. Nobody on the internet can start a connection to them.
- **Private data subnets** hold the databases. Only the app tier can talk to them.

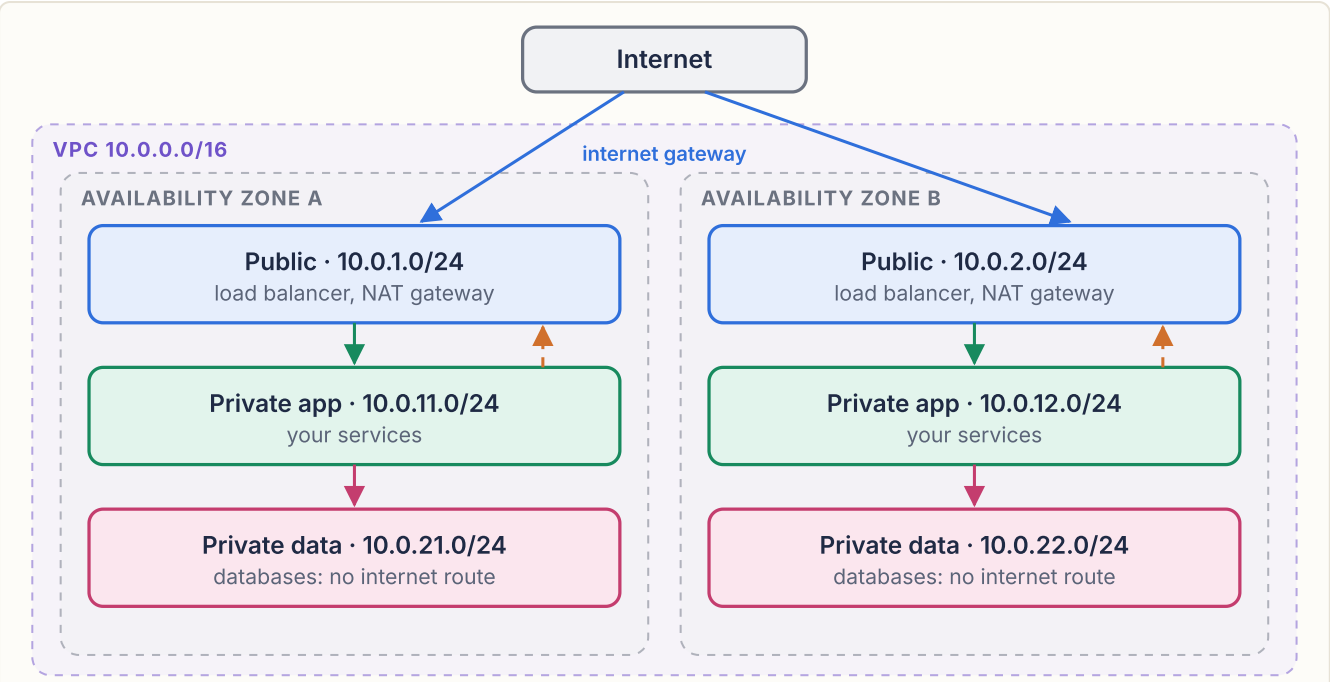


Figure 3. A two-zone VPC. Traffic enters only at the load balancers in the public subnets; apps go out through the NAT gateway (dashed orange arrows, outbound only); the data subnets have no internet route at all.

Why put databases in private subnets? Because there is simply no route from the internet to them. Even if a password leaks or a firewall rule is wrong, attackers cannot reach the database directly. That is **defense in depth**: routing is one layer, security groups are another, credentials a third.

WORKED EXAMPLE: THE ADDRESS PLAN

VPC `10.0.0.0/16` (65,536 addresses). Use `/24` subnets: public `10.0.1.0/24` and `10.0.2.0/24`, app `10.0.11.0/24` and `10.0.12.0/24`, data `10.0.21.0/24` and `10.0.22.0/24`. That is 6 × 256 = 1,536 addresses used, 6 × 251 = **1,506** usable on AWS, and over 97% of the block left for a third zone or new tiers. If the app tier will run thousands of containers that each take an IP, make the app subnets `/20` (4,091 usable each) instead.

PLAN AHEAD

Give the VPC a large block (a `/16`) and never overlap it with other VPCs or your office network. Peering, VPNs and transit gateways cannot route between two networks that both claim `10.0.0.0/16`, and renumbering a live VPC means rebuilding it. A simple fix: give each VPC its own slice, such as `10.0.0.0/16` for prod, `10.1.0.0/16` for staging, `10.2.0.0/16` for dev.

COMMON MISTAKES

- Reading `/24` as "24 hosts". It is 24 *network* bits, leaving 8 host bits: 256 addresses.
- Thinking all of 172.x is private. Only 172.16.0.0 to 172.31.255.255 is.
- Using the default small VPC or tiny subnets, then running out of IPs when containers or Lambda functions each take one.
- Overlapping VPC ranges with each other or with the office network.
- Putting databases in public subnets "just for now".

6 Key terms

IPv4 / IPv6: 32-bit / 128-bit addresses

Prefix length: number of fixed network bits

NAT: swaps private source IPs for a public one

Octet: one of the four 8-bit numbers in IPv4

Subnet: a slice of the VPC block, in one zone

Internet gateway: VPC route target for public subnets

CIDR: block = start address / prefix length

Private range: 10/8, 172.16/12, 192.168/16

Defense in depth: several independent layers of protection

7 Interview questions

Q1. What does `10.0.0.0/16` mean? BASIC

The first 16 bits (`10.0`) are fixed as the network, leaving 16 bits for hosts: 2^{16} = 65,536 addresses, from 10.0.0.0 to 10.0.255.255.

Q2. How many addresses are in a /24, and how many /24s fit in a /16? BASIC

A /24 has 32 − 24 = 8 host bits, so 256 addresses (251 usable on AWS, 254 on a classic network after network and broadcast). A /16 holds 2^8 = 256 of them.

Q3. What are the private IPv4 ranges, and why do they exist? BASIC

10.0.0.0/8, 172.16.0.0/12 and 192.168.0.0/16. They are not routed on the internet, so every organisation can reuse them internally; NAT translates them to a public address to go out.

Q4. Design the subnets for a three-tier app in two availability zones. SCENARIO

VPC 10.0.0.0/16. Per zone: a public /24 for load balancers and the NAT gateway (route 0.0.0.0/0 to the internet gateway), a private app subnet (default route to NAT), and a private data subnet with no internet route. Six subnets, each in one zone.

Q5. Why put databases in private subnets if they already have passwords and security groups? SCENARIO

Defense in depth. With no route from the internet, a leaked password or a wrong firewall rule is still not enough for an attacker to connect. Only the app tier can reach the database.

Q6. Your company wants to peer a new VPC with an existing one and the office VPN. What do you check first? SCENARIO

That the CIDR blocks don't overlap. If the new VPC uses 10.0.0.0/16 and so does the old one, routing between them is impossible without renumbering; pick, say, 10.1.0.0/16.

Q7. A /28 subnet on AWS: how many instances can you launch? TRICKY

A /28 has 2^4 = 16 addresses. AWS reserves 5, so 11 usable. It is the smallest subnet AWS allows, and it fills up fast.

Q8. Do instances in a private app subnet need public IPs to download updates? TRICKY

No. They send traffic to the NAT gateway in a public subnet, which uses its own public IP. Connections can go out and replies come back, but nothing on the internet can open a connection in.

Next: SD-N-014 · Routing and NAT: how packets find their way, and why your phone shares one public address backendroadmap.com